

Lecture 2 Cyber Security

What is Cyber Security

Information security means the **rules and methods** used to protect data and information from people who are **not allowed to see or use it**. It helps stop **unauthorized access, misuse, changes, damage, or deletion** of data.

Information security also means **controlling who can access data in a network**. This control is usually managed by the **network administrator**. Each user gets a **username (ID) and password**, which allows them to access only the **resources they are permitted to use** on the network.

Objectives of Information Security

- Confidentiality
- Integrity
- Availability

Confidentiality means protecting information so that **only authorized people can access it**. Sensitive information should not be seen or used by anyone who does not have permission.

If confidentiality is broken, it means someone who should not have access **got the information**, either by mistake or on purpose. This is called a **confidentiality breach**.

A confidentiality breach usually **cannot be fixed**. Once the secret information is revealed, it **cannot be hidden again**.

Integrity means making sure information is **authentic and correct**. It also means that the information **has not been changed** and that the source of the information is **real and trustworthy**.

For example, imagine you have a website where you sell products. If an attacker can enter the website and **change the prices of products**, so they can buy anything at their own chosen price, that is a problem of integrity. It happens because the information (prices) has been **altered**, which should not be allowed.

Availability means that information is **accessible to authorized users whenever they need it**. If attackers cannot access the information, they may try to attack the system using methods like a **denial of service attack**, which can shut down the server and make the website unavailable. This happens because the information is not available to legitimate users.

For example, a university website should always be available for students and teachers so they can access important information anytime.

Availability can be maintained by using **redundancy**, which means having backup systems so that if one system fails, another can continue working.

Foundations of Cyber Security

- People
- Processes
- Technology



Also called People, Process and Technology (PPT) framework.

Foundation of Cyber Security

People are the individuals who work on the network. They can be **network users** or **network administrators**. People are the most important part of network security because without them, nothing can work.

Network administrators should be well trained so they can **maintain security in the network** and protect it from problems.

Network users must understand and follow the security rules of the organization. They should know:

- What network resources they are allowed to use.
- Which information they can access.
- What their permissions and limits are.
- Whether they are allowed to copy data on a USB drive and take it home or not.

Following these rules helps keep the network safe and secure.

Foundation of Cyber Security

A process means a set of steps or actions that must be followed to achieve a goal.

Processes help IT professionals **apply network security in an organized and efficient way**. They also help in responding to security problems quickly and avoiding mistakes that could harm the network.

For example, if someone wants to access the network from home, they should use a **VPN (Virtual Private Network)** to do it securely.

Foundation of Information Security

Technology is the most important part of network security. Without technology, we cannot achieve proper network security in today's modern world.

If a network does not use technology-based security systems, there would be no way to stop intrusions (unauthorized access). It would also be impossible to keep a record (log) of security incidents that happen in the system.

Cyber Security Methods

Access control means you should be able to **block unauthorized users and devices** from entering your network. Users who are allowed to access the network should only use the **limited resources** that they have permission to use.

Anti-malware means protection against harmful software like **viruses, worms, and trojans**. These programs try to spread through the network and can stay hidden in infected machines for days or weeks. Security systems should **prevent malware from entering the network** and remove it if it does manage to enter.

Application security means protecting software applications because insecure applications are often the way attackers gain access to the network. To secure applications, you should use **hardware, software, and security procedures**.

Behavioral analytics means understanding what normal network behavior looks like. This helps you detect unusual activities or security problems as soon as they happen.

Data loss prevention means protecting sensitive information from being leaked. Humans are usually the weakest part of security because they may accidentally or deliberately share sensitive data. Therefore, technologies and security processes should be used to ensure that employees do not send important data outside the network.

Email security means protecting emails because phishing is one of the most common ways attackers try to access a network. Email security tools can block harmful incoming emails and prevent sensitive information from being sent outside the network.

Firewalls are one of the most important tools for network security. They work by following predefined rules to allow or block internet traffic. A firewall creates a barrier between your trusted network and the outside internet. It does not replace other security measures but is still essential for protection.

Information Security Methods

Easy Words Translation:

Intrusion detection and prevention systems scan network traffic to find and block attacks. They do this by comparing network activities with databases of known attack patterns so they can identify suspicious behavior.

Mobile devices and wireless security are important because wireless devices have the same security risks as other network gadgets. However, they can connect to almost any wireless network, which increases security risks. Therefore, extra protection and careful monitoring are required.

Cyber Security Methods

Network segmentation means dividing a network into smaller parts to improve security and management. This makes it easier to apply security rules. For example, an organization can create different **VLANs (Virtual Local Area Networks)** for different departments.

VPN (Virtual Private Network) is a tool that creates a **secure and encrypted connection** between a device and a network over the public internet. It authenticates the communication and forms a safe “tunnel” so that data can travel securely.

Cyber Security Basic Terminologies

Threat is a possible danger that can break the security system and cause harm.

An **adversary or threat agent** is the person or entity that creates the threat and tries to attack the network or its resources.

Risk means the chance that loss, damage, or destruction of network services may happen because of a threat.

An **attack** is any method or action used by someone to **maliciously try to break or compromise the network security**.

.....

What is a cyberattack?

A **cyberattack** is when hackers or cybercriminals try to enter a computer system or network. They usually do this to **change, steal, destroy, or expose important information**.

The main goals of a cyberattack can be:

1. **Stealing Sensitive Information:** Getting confidential data such as personal information, bank details, or important company information.

2. **Disrupting Services:** Stopping normal users from using websites, networks, or online services.
3. **Gaining Unauthorized Access:** Using weaknesses in a system to enter it without permission and then **change, steal, or delete data**.
4. **Extorting Money:** Asking for money (ransom) to give back access to locked files or to stop the attack.
5. **Sabotaging Infrastructure:** Attacking important systems like **electric power grids, hospitals, or transportation networks** to create major problems and disruptions.

Types of Cyberattacks

1. Malware
2. Denial-of-Service (DoS) Attacks
3. Phishing
4. Spoofing
5. Identity-Based Attacks
6. Code Injection Attacks
7. Supply Chain Attacks
8. Social Engineering Attacks
9. Insider Threats
10. DNS Tunneling
11. IoT-Based Attacks
12. AI-Powered Attacks

1. Malware

Easy Words Translation:

Malware (malicious software) is any program or code that is created to **damage a computer, network, or server**.

Malware is one of the **most common types of cyberattacks**. It includes many different types of harmful software such as **ransomware, trojans, spyware, viruses, worms, keyloggers, and bots**.

All these programs are designed to **harm systems, steal information, or control computers in a malicious way**.

TYPES

Ransomware

In a **ransomware attack**, a hacker locks or encrypts a victim's data so the owner cannot access it. The attacker then asks for **money (ransom)** and promises to give a **decryption key** to unlock the data after payment.

Ransomware attacks often start when someone **clicks a malicious link in a phishing email**. They can also happen when a system has **unpatched security weaknesses or wrong security settings**.

Spyware

Spyware is a type of harmful software that secretly enters a computer or device. It **collects information about a user's internet activities** without their knowledge or permission.

This information can include things like **websites visited, personal data, or login details**, which can then be used by attackers.

Adware

Adware is a type of spyware that tracks a user's online activities to decide which advertisements should be shown to them.

Adware is not always harmful, but it can **slow down the device's performance** and **reduce the user's experience** by showing many ads.

Trojan

A **Trojan** is a type of malware that **looks like normal or safe software**, but it is actually harmful. It may appear as a **system program or a harmless file**, such as a free download.

Trojans are usually installed using **social engineering tricks**, such as **phishing emails or fake websites** that convince users to download or install the file.

Worm

A **worm** is a type of malicious program that **copies itself and spreads to other computers automatically**.

A worm can enter a system through **software weaknesses (vulnerabilities)** or through **phishing emails or smishing (fake SMS messages)**.

Rootkit

A **Rootkit** is a type of malware that is designed to give attackers **secret control over a computer, network, or application**. Some rootkits are even more dangerous because they infect the **Master Boot Record (MBR)** of a computer before the operating system starts. Because they load before the system boots, they are **very difficult to detect and remove**.

Mobile malware

Mobile malware is harmful software that is made to attack **mobile devices such as smartphones and tablets**.

It can enter a mobile device through **malicious downloads, operating system weaknesses, phishing emails, smishing (fake SMS messages), or by using unsecured Wi-Fi networks**.

Scareware

It is a type of malware that **frightens users by showing fake warnings** that their computer is infected with a virus. Usually, it appears as a **pop-up message** on the screen.

The goal of scareware is to **trick users into downloading fake antivirus software** to remove the so-called virus. When the user installs this fake antivirus program, **malware can then infect the computer**.

Keyloggers:

Keyloggers are tools that **record everything a person types on a keyboard**. Some keyloggers are used for legal purposes, but many are used maliciously. In a keylogger attack, the software records **every keystroke** on the victim's device and sends this information to the attacker.

Botnet:

A botnet is a **group of computers infected with malware** and controlled by a hacker called a **bot herder**. The hacker uses these infected computers to launch attacks, such as **crashing networks, spreading malware, stealing login information, or performing heavy computer tasks**.

Wiper Attack:

A wiper attack is designed to **permanently delete or damage data** on targeted systems. These attacks are often seen in **political conflicts or hacktivism activities**.

1. Denial-of-Service (DoS) Attack

A **Denial-of-Service (DoS) attack** is a harmful attack where an attacker sends **a large number of fake requests** to a network or website. This overloads the system and **stops normal users from using the service**.

During a DoS attack, users cannot do normal tasks such as **checking emails, opening websites, or accessing online accounts** because the system becomes very busy or crashes.

Most DoS attacks **do not destroy data**, but they waste the organization's **time, money, and resources** to fix the problem and restore services.

Difference between DoS and DDoS:

- **DoS attack:** Comes from **one computer or system**.

- **DDoS (Distributed Denial-of-Service) attack:** Comes from **many computers at the same time**.

DDoS attacks are **faster and harder to stop** because the attack is coming from many systems.

2. Phishing

Phishing is a type of cyberattack where attackers try to **trick people into giving sensitive information** like passwords, bank details, or account numbers.

Attackers usually do this using **emails, SMS messages, phone calls, social media, or fake websites**. Sometimes they also trick users into **downloading malicious files** that install viruses on their computer or phone.

TYPES OF **Phishing**

Spear Phishing

Spear phishing is a special type of phishing attack that targets specific people. The attacker first researches the target and then writes a message that seems personal and relevant to them. These messages look very real, which makes spear phishing difficult to detect. It is called “spear” phishing because the attacker focuses on one specific target.

Whale Phishing

Whale phishing is a type of social engineering attack that targets high-level executives or important employees of a company. The goal is to steal money or confidential business information.

Smishing

Smishing is phishing through text messages (SMS). Attackers send fake messages to trick people into sharing sensitive information such as passwords, usernames, or credit card details. The message may pretend to be from a bank or a delivery company to appear trustworthy.

Vishing

Vishing is voice-based phishing. Attackers use phone calls or voice messages to pretend they are from a trusted organization. Their goal is to trick people into revealing private information such as bank details or passwords.

SPOOFING

Spoofing is a technique where a cybercriminal **pretends to be a trusted person or source**. By doing this, they trick users and gain access to systems to **steal information, demand money, or install harmful software**.

Types of Spoofing

- **Domain Spoofing** – A type of phishing where the attacker creates a fake website or email that looks like a real business or person. At first glance, it seems genuine, but small differences reveal it is fake.
 - **Email Spoofing** – A cyberattack where the sender's address is forged so the email looks like it came from a trusted source. Because the recipient trusts the sender, they may open the email and click harmful links.
 - **IP Spoofing** – A method where the attacker hides the real source of IP packets, making it difficult to trace where the attack is coming from.
-

IDENTITY-BASED ATTACKS

Identity-based attacks are very difficult to detect. When a user's credentials are stolen and an attacker uses them, it becomes hard to distinguish normal user activity from the hacker's actions.

Types of Identity-Based Attacks

- **Kerberoasting** – An attack that tries to crack the password of a service account in Active Directory by requesting an encrypted ticket.
- **Man-in-the-Middle (MITM) Attack** – An attack where the hacker secretly listens to communication between two parties to steal data such as passwords or bank details. The attacker may also manipulate the conversation.
- **Pass-the-Hash Attack** – An attack where the hacker steals a hashed password and uses it to access the system without knowing the actual password.
- **Golden Ticket Attack** – A technique where attackers gain unlimited access to a domain by exploiting Active Directory vulnerabilities.
- **Silver Ticket Attack** – A forged authentication ticket that allows access to specific services in the system.
- **Credential Harvesting** – Collecting large amounts of login details (usernames and passwords) to access accounts or sell them.
- **Credential Stuffing** – Using stolen credentials from one account to try logging into other accounts because people often reuse passwords.
- **Password Spraying** – Trying one common password on many accounts instead of attacking one account with multiple passwords, reducing the chance of account lockouts.
- **Brute Force Attack** – A method where the attacker repeatedly guesses passwords until they find the correct one.

CODE INJECTION ATTACKS

Code injection attacks happen when hackers insert harmful code into a system to change how it works.

Types of Code Injection

- **SQL Injection** – A vulnerability where attackers insert malicious SQL commands to access or manipulate database data. They can steal, change, or delete information.
 - **Cross-Site Scripting (XSS)** – An attack where harmful code is injected into a website. When users visit the site, the code runs in their browser and may steal information.
 - **Malvertising** – Attackers place infected ads on websites. When users click the ad, malware is installed on their device.
 - **Data Poisoning** – A cyberattack that corrupts training data of AI or machine learning models, causing incorrect or biased results.
-

SUPPLY CHAIN ATTACKS

A supply chain attack targets third-party software or service providers. Attackers insert malicious code into software so that all users of the software become infected. Because modern software relies on third-party components, these attacks can be very dangerous.

SOCIAL ENGINEERING ATTACKS

Social engineering is a technique where attackers use psychological tricks to manipulate people into sharing sensitive information.

Examples

- **Pretexting** – The attacker creates a fake story to gain trust and access information.
 - **Business Email Compromise (BEC)** – Attackers impersonate trusted employees to trick others into sending money or data.
 - **Disinformation Campaign** – Spreading false information to influence opinions.
 - **Quid Pro Quo** – Offering something in return for sensitive information.
 - **Honeytrap** – Using fake online relationships to trick victims into giving money or access.
 - **Tailgating (Piggybacking)** – Physically following an employee into a restricted area by pretending to be authorized.
-

INSIDER THREATS

Insider threats come from people inside an organization (employees or former employees). They are dangerous because they already have access to the network and data.

Some insiders act maliciously for financial gain, while others are negligent and make mistakes. Organizations should provide security training and monitoring to reduce risks.

DNS TUNNELING

DNS tunneling is an attack that uses DNS requests to bypass security and transfer data. Hackers encode data inside DNS queries, allowing them to communicate with the infected system and steal information.

IoT-BASED ATTACKS

IoT attacks target internet-connected devices (like smart cameras or home devices). Once compromised, hackers can control the device, steal data, or use it to launch other attacks such as DoS or DDoS.

As more devices become connected to the internet, these attacks are expected to increase.

AI-POWERED ATTACKS

Hackers also use artificial intelligence to launch attacks.

Types of AI-Based Attacks

- **Adversarial AI/ML** – Manipulating AI systems by introducing false data.
 - **Dark AI** – Using AI to exploit vulnerabilities and cause damage.
 - **Deepfakes** – AI-generated fake images, videos, or audio that look real and can mislead people.
 - **AI-Generated Social Engineering** – Chatbots that interact like humans to trick users into sharing information.
-

Agenda

Agenda

- The threat environment—attackers and their attacks
- Basic security terminology
- Employee and ex-employee threats
- Traditional external attackers
- The criminal era and competitor threats
- Cyberwar and cyberterror

Employee and Ex-employee threats

2.2 Employee and Ex-Employee Threats

- **2.2.1 Employees and Ex-Employees Are Dangerous**
 - Dangerous because
 - They have knowledge of internal systems
 - They often have the permissions to access systems
 - They often know how to avoid detection
 - Employees generally are trusted
 - Further, IT and especially IT security professionals are the greatest employee threats
 - "Who will guard the guards themselves?"

Employee and Ex-Employee Threats

Employees and ex-employees are dangerous because they have extensive knowledge of systems, have the credentials needed to access sensitive parts of the systems, often know how to avoid detection, and can benefit from the trust that usually is accorded to "our people"

Employee and Ex-Employee Threats

Sophisticated computer knowledge not required

For example, In 23 financial cybercrimes committed between 1996 and 2002, 87 percent were accomplished without any "sophisticated programming".

Employee sabotage means when an employee intentionally **steals or destroys company resources**. These resources can be **physical (like computers and equipment)** or **digital (like software and data)**.

For example, an employee might:

- Steal or damage hardware
- Delete or destroy important data
- Install harmful programs like a **time bomb or logic bomb** in a computer so it causes problems later.
- To prevent employee sabotage, organizations should pay attention to how employees feel and use strong security measures.
- Another way to stop sabotage is to train managers so they can notice behaviors that might lead to sabotage. Organizations should also try to remove reasons that make employees unhappy or dissatisfied, because unhappy employees may become a security risk.

Example:

- A company notices that an employee is very unhappy because of heavy workload and lack of appreciation. Instead of ignoring the problem, the manager talks to the employee, reduces workload, and motivates them. The company also monitors system activities and uses security rules to prevent data misuse.
- Because the employee feels valued and monitored, they have no reason to harm the company or its data.

Employee and Ex-Employee Threats

- ▶ Note that the motivation for hacking is irrelevant
- ▶ Penalties are the same whether you were trying to steal a million dollars or were merely "testing security"

Access has to be intentional, damage does not...

Employee and Ex-Employee Threats

▶ Employee Hacking

- Hacking is intentionally accessing a computer resource without authorization or in excess of authorization
- Authorization is the key

Employee and Ex-Employee Threats

- ▶ **Employee Financial Theft**
 - Misappropriation of assets
 - E.g. assigning them via computer to themselves
 - Theft of money
 - E.g. manipulation of an application to be paid a bonus
- ▶ **Employee Theft of Intellectual Property (IP)**
 - Copyrights and patents (formally protected)
 - Trade secrets: plans, product formulations, business processes, and other info that a company wishes to keep secret from competitors

Employee and Ex-Employee Threats

- ▶ **Employee Theft of Intellectual Property (IP)**

Intellectual Property (IP) is the information owned by the company and protected by law.

Trade secrets are pieces of sensitive information that a firm acts to keep secret from competitors; e.g. plans, price lists and customer lists, etc.

2.2.6 Employee Extortion

The attacker tries to get **money or other things** from someone by **threatening them**. The attacker says they will do something **harmful or bad** to the victim if the victim does not give what they want.

For example the employee might deploy a logic bomb on the company's computer. Stealing Intellectual Property (IP) and demanding money for not passing on the information is also extortion.

Harassment of Other Employees

Via e-mail

Displaying inappropriate material

Other Types of Abuse – Internet Abuse

Internet abuse means using the internet at work in a **wrong or improper way**.

Examples:

- **Downloading inappropriate material** (bad or offensive content). This can cause legal problems or bring viruses into the computer.
- **Downloading pirated software, music, or videos.** This means downloading illegal copies, which can lead to **copyright penalties**.
- **Using the internet too much for personal reasons during work**, which wastes company time and resources.

Non-Internet Computer Abuse

Unauthorized access to private personal data on internal systems by curious employees

Carelessness

Loss of computers or data media containing sensitive information

Carelessness leading to the theft of such information

Other “Internal” Attackers

Contract workers who work for the firm for brief periods of time

Workers in contracting companies

.....

Traditional External Attackers: Hackers

Traditional Hackers:

Hackers are skilled computer experts who use their technical knowledge to **break or bypass the security of computer systems**. They do this to gain **unauthorized access to data or networks**.

Types of Hackers

There are three main types of hackers:

Black hat hacker

White hat hacker

Grey hat hacker

Black Hat Hackers:

Black hat hackers are people who **break into computer systems with bad intentions**. They may **steal credit card information, change bank databases, or shut down computer systems**.

Black hat hackers are also called **crackers**. They are considered **criminals** because they perform illegal and harmful activities.

White Hat Hackers:

White hat hackers are **authorized and trained hackers** who help organizations improve their security.

They test computer systems to **find weaknesses (security holes)** so the company can fix them before criminals attack.

Their job is to **protect systems from cybercrime**. They work legally and follow government rules, which is why they are also called **ethical hackers**.

Grey Hat Hackers:

Grey hat hackers are **between white hat and black hat hackers**. They are **not officially authorized** to hack systems.

Sometimes they **hack to find security problems and help fix them**, but they do it **without permission**, which is illegal. So their actions can be **both good and bad**.

Hackers Motivations

- Financial Gain
- Validation of skills
- sense of power
- To increase reputation among other hackers
- To damage the product or moral
- Terrorism
- Warfare

Exploit:

An **exploit** is the specific method or trick an attacker uses to **break into a computer system** by taking advantage of a weakness in security.

When the attacker actually **uses that method to attack the computer**, it is called **exploiting the host**.

Example:

Source IP Spoofing – when an attacker **hides or changes their real IP address** to pretend they are another trusted computer.

IP Spoofing:

IP spoofing is when an attacker **changes or hides the real IP address** of their computer while sending data on the internet.

They do this to **hide their identity** or **pretend to be another trusted computer system**. This helps them attack or access systems without being easily detected.

Chain of Attack Computers:

In this method, the attacker does not attack directly. Instead, they **use several hacked computers in a chain** to hide their identity.

- The attacker sends the attack through **many victim computers**.
- The attack packets show the **IP address of the last computer in the chain**, not the real attacker.
- The **final computer** receives responses from the victim system and **sends them back to the attacker**.

Social Engineering:

Social engineering is a trick used by hackers to **fool people into giving sensitive information**.

- The attacker tries to **trick users into doing something unsafe**, like sharing their **username, password, or other private information**.
- It is often successful because it **targets human weaknesses** (trust, fear, curiosity) instead of attacking the computer system directly.

Denial-of-Service (DoS) Attack:

A Denial-of-Service attack is a cyberattack where the hacker makes a server or network unavailable to its users.

- The attacker does this by sending too many fake requests to the system. This overloads the system so it cannot handle normal requests. As a result, legitimate users cannot access the service.
- The goal is to **disrupt the service** so that it stops working temporarily or completely.
-

Distributed Denial-of-Service (DDoS) Attack:

In a DDoS attack, the hacker uses many different computers or sources to send fake traffic to the victim's system.

- Because the attack comes from many places, it is very hard to stop by blocking only one source.
- A DoS or DDoS attack is like a group of people crowding the entrance of a shop so that real customers cannot enter. This disrupts normal service and prevents legitimate users from accessing the system.